Report: test di login su DVWA con Burp Suite

Data: 22/10/2026

Autore: Sergiu Hanganu

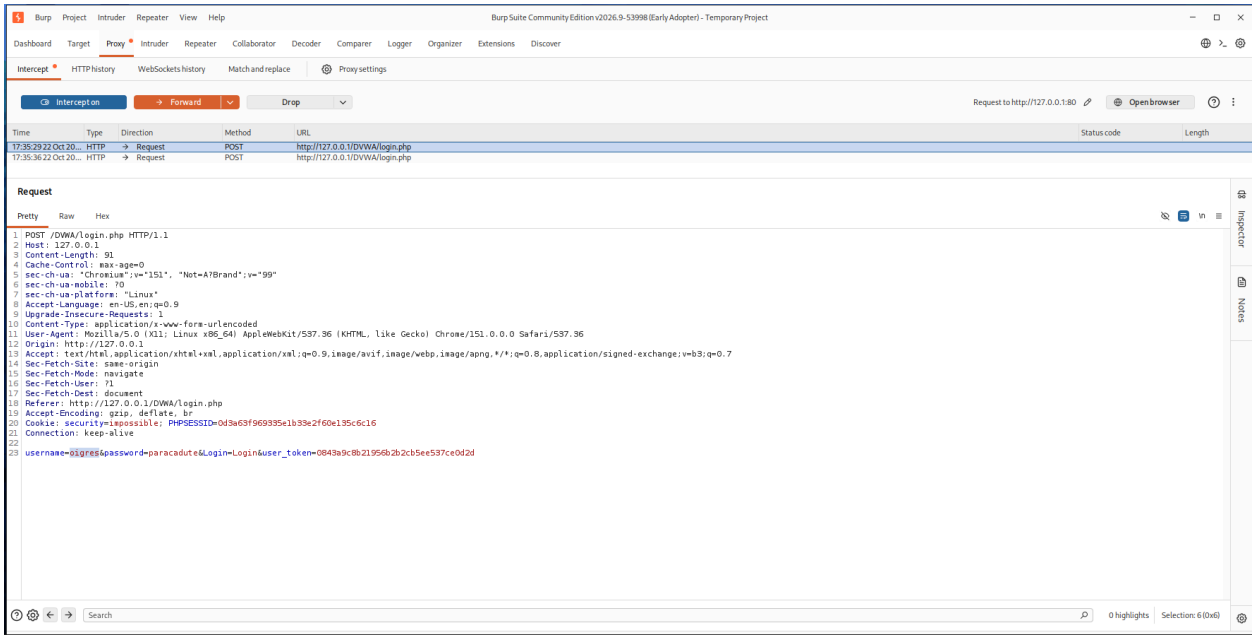
Ambiente: DVWA (Damn Vulnerable Web Application) su `http://127.0.0.1`, lab locale
Strumenti: Burp Suite Community v2026.9, Chromium

Obiettivo

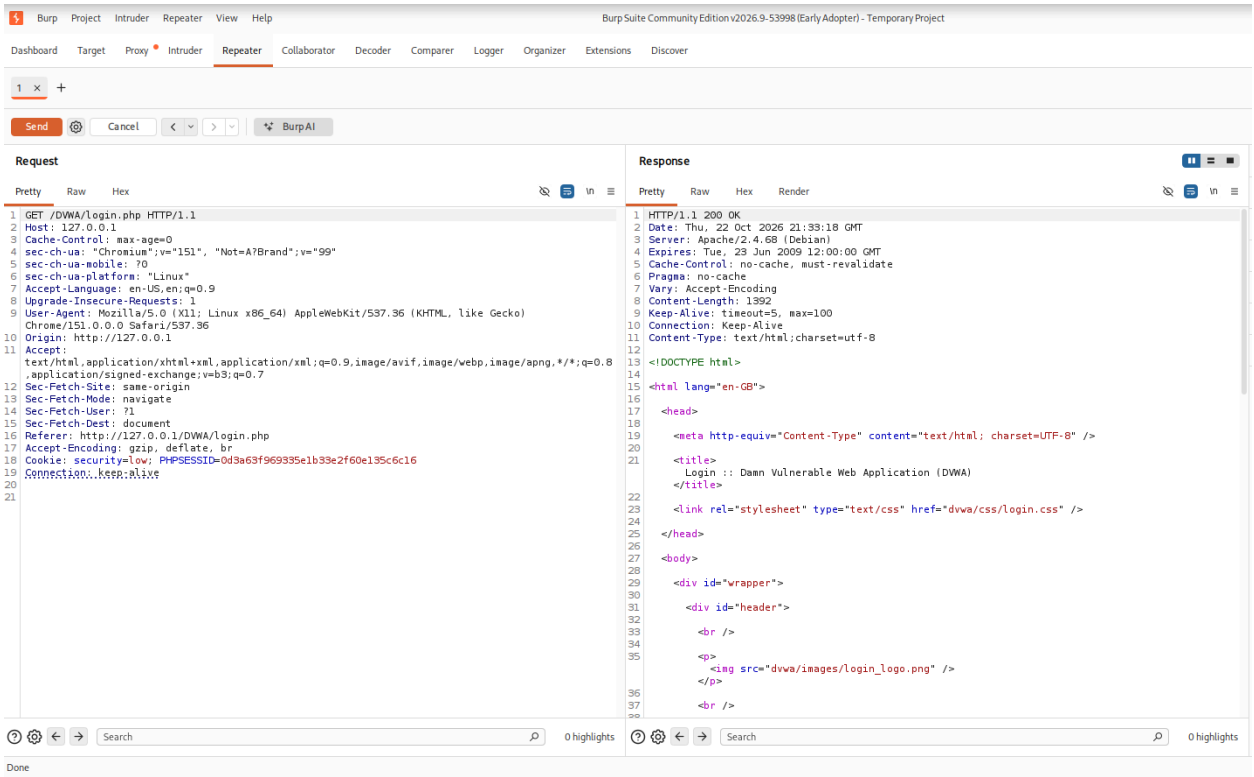
Verificare come il form di login gestisce richieste alterate tramite proxy, modificando username, password e livello di sicurezza.

Procedura

1. Attivato Burp Proxy con *Intercept on*.
2. Inviato il form di login dal browser: Burp ha intercettato la richiesta `POST /DVWA/login.php`, contenente `username`, `password`, `Login` e `user_token`



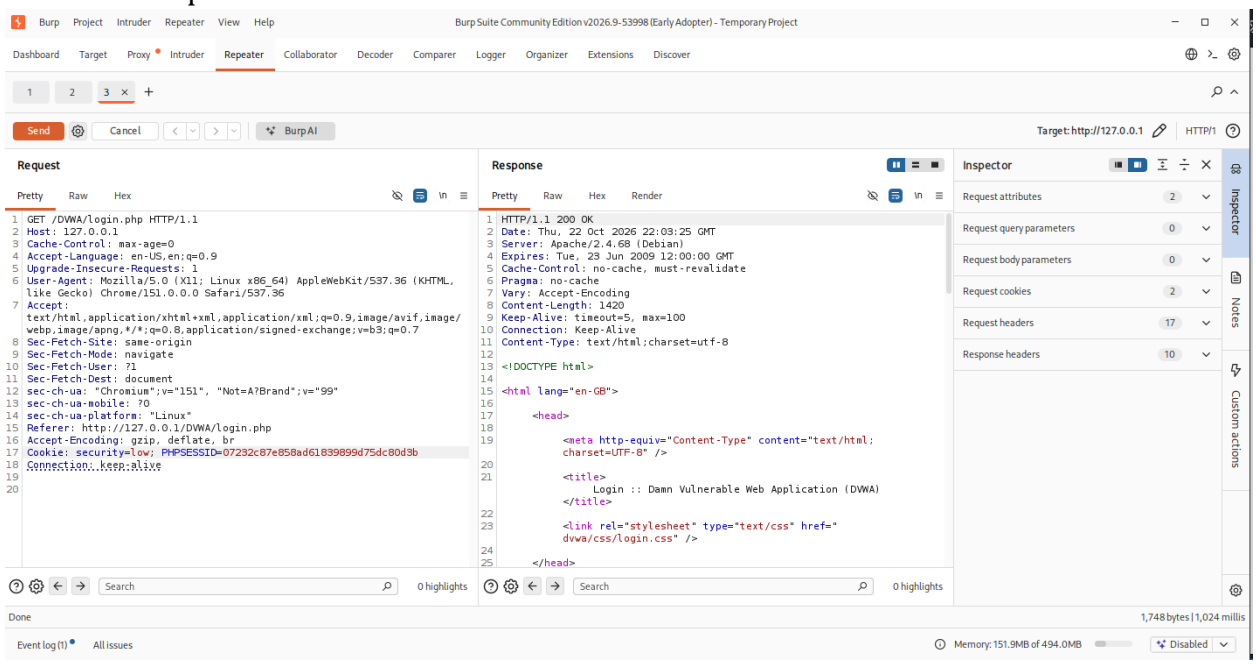
3. Modificati i valori di `username` e `password` nel corpo della richiesta, poi inoltrata con *Forward*.
4. Inviata la richiesta al Repeater. Nel cookie `security` il valore è stato cambiato da `low` a `impossible`, quindi la richiesta è stata rispedita.
5. Osservata la risposta del server


Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Decoder Comparer Logger Organizer Extensions Discover
1 ×
Send Cancel BurpAI
Request
Pretty Raw Hex
GET /DVWA/login.php HTTP/1.1
Host: 127.0.0.1
Cache-Control: max-age=0
sec-ch-ua: "Chromium";v="151", "Not=A?Brand";v="99"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Linux"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Origin: http://127.0.0.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: http://127.0.0.1/DVWA/login.php
Accept-Encoding: gzip, deflate, br
Cookie: security=low; PHPSESSID=0d3a63f969335e1b33e2f60e135c6c16
Connection: keep-alive
Search 0 highlights
Response
Pretty Raw Hex Render
HTTP/1.1 200 OK
Date: Thu, 22 Oct 2026 21:33:18 GMT
Server: Apache/2.4.68 (Debian)
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 1392
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
<!DOCTYPE html>
<html lang="en-GB">
<head>
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
<title>
Login :: Damn Vulnerable Web Application (DVWA)
</title>
<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />
</head>
<body>

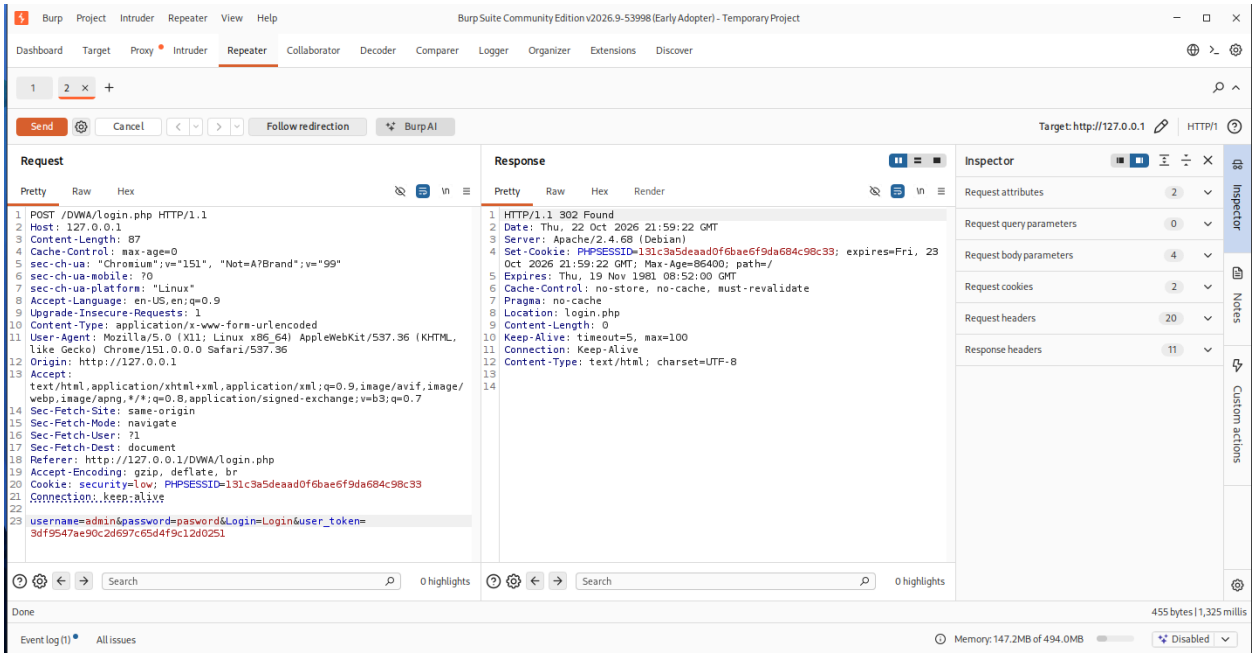
Search 0 highlights
Done

Risultati

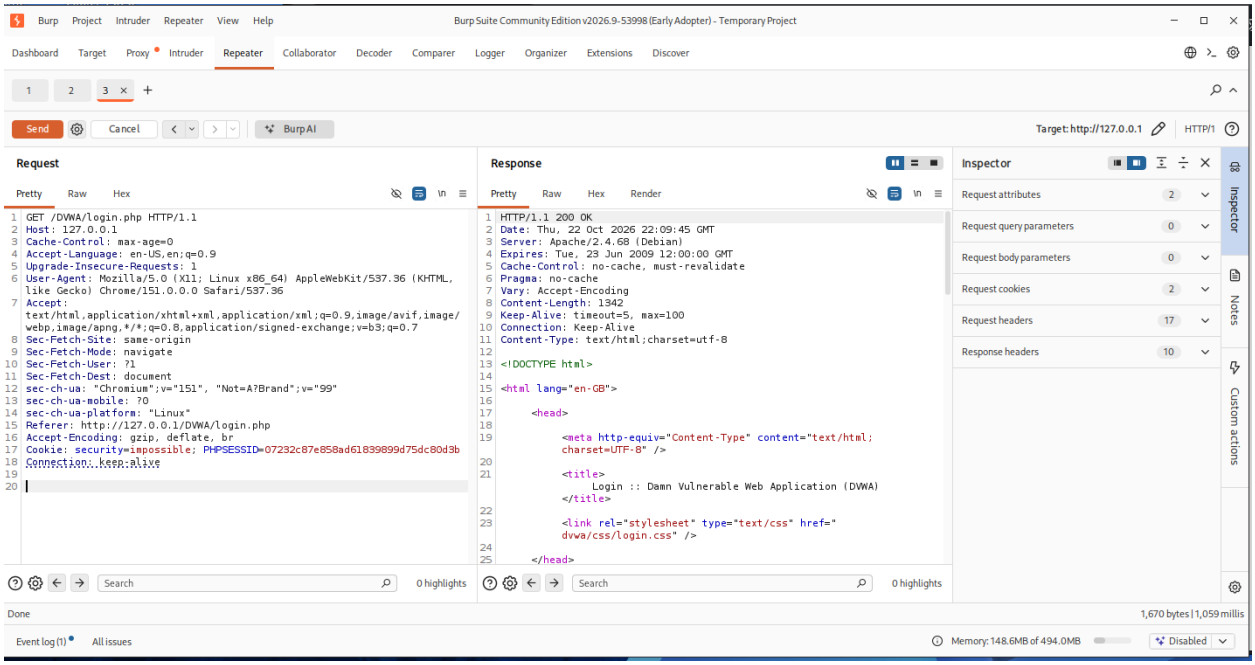
- Stato della risposta: 200 OK



- Versione Login con stato risposta : 302 Found



- Esito con cookie `security=impossible`:



Osservazioni

- Il `user_token` è un parametro di sicurezza: se non corrisponde alla sessione, la richiesta va rifiutata.
- Con `security=impossible`, DVWA usa query preparate e controlli aggiuntivi. Modificare solo username e password non dovrebbe bypassare il login. Un risultato diverso andrebbe verificato e documentato.

Conclusioni

Ho potuto verificare il funzionamento di Burp anche se solo su una rete interna , ciò mi ha permesso di modificare username e password a mio piacimento bloccando difatti il Browser in attesa di una mia mossa.